Escuela Colombiana de Ingeniería Julio Garavito

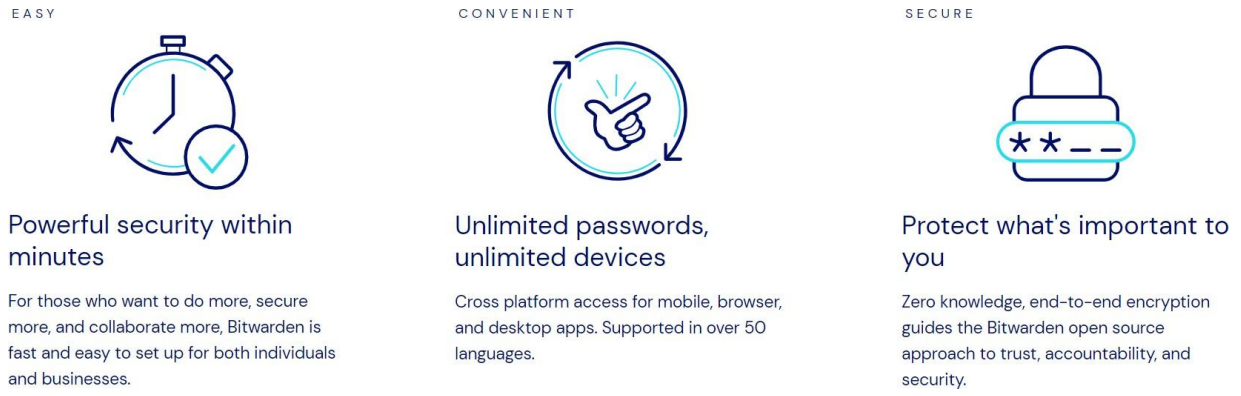
Taller No.4 - Crypto Bitwarden

Ángel Nicolas Cuervo Naranjo

Ing. Javier Ivan Toquica

Bogota D.C
20/03/2026
2026-1

Bitwarden es un gestor de contraseñas libre y de código abierto que almacena información sensible — como credenciales de sitios web— en una caja fuerte encriptada. El servicio está disponible en interfaz web, aplicaciones de escritorio, complementos para navegador, aplicaciones móviles e interfaz de línea de comandos. Bitwarden ofrece un servicio alojado en la nube y también posee la habilidad de implementar soluciones en software local.



Preguntas a desarrollar:

1. Describa los mecanismos de criptografía simétrica utilizados (describa los algoritmos)
2. Describa los mecanismos de criptografía asimétrica utilizados (describa los algoritmos)
3. Por qué el masterpassword no puede ser recuperado?
4. Describa los mecanismos para proteger el acceso al baúl de contraseñas
5. Describa el mecanismo de protección de datos en reposo

Objetivo:
Este taller tiene como finalidad afianzar y profundizar los conceptos trabajados en el aula de clase, tomando como referencia la documentación oficial de Bitwarden para explorar, de forma aplicada, los fundamentos de la criptografía moderna., la protección segura de contraseñas mediante hashing y derivación de claves, así como la gestión controlada de accesos a múltiples servicios y plataformas.

Más allá de la teoría, el taller busca desarrollar una comprensión crítica sobre por qué la criptografía es un pilar fundamental en la seguridad de la información, fomentando en el estudiante buenas prácticas en el manejo de credenciales y el uso responsable de herramientas de gestión de contraseñas en contextos personales y profesionales.

Solucion:

1. Descripcion general de los mecanismo de criptografia simetricos.

Descripción General de los Mecanismos de Criptografía Simétricos

La criptografía simétrica se caracteriza por el uso de una única clave tanto para cifrar como para descifrar la información, lo que la convierte en un enfoque eficiente y robusto cuando se gestiona correctamente. Bitwarden hace uso de varios mecanismos simétricos que trabajan en conjunto para garantizar la confidencialidad, integridad y autenticidad de los datos del usuario.

1. AES-256 en Modo CBC

El algoritmo central del esquema de cifrado de Bitwarden es el Advanced Encryption Standard (AES) con clave de 256 bits, operando en modo Cipher Block Chaining (CBC). Este estándar es ampliamente utilizado por gobiernos, militares y empresas tecnológicas a nivel mundial, precisamente por la solidez que ofrece ante ataques de fuerza bruta y criptoanálisis.

El modo CBC introduce un vector de inicialización (IV) de 128 bits que encadena cada bloque cifrado con el anterior, impidiendo que bloques con contenido idéntico produzcan el mismo resultado cifrado, lo que elimina patrones predecibles y refuerza significativamente la seguridad. Dentro de Bitwarden, AES-256 CBC cumple dos propósitos fundamentales:

- Transformar la Generated Symmetric Key en la Protected Symmetric Key, protegiéndola antes de ser almacenada.
- Cifrar el contenido completo del baúl del usuario, usando claves derivadas directamente de la contraseña maestra.

2. HMAC (Hash-based Message Authentication Code)

HMAC no es un algoritmo de cifrado en sí mismo, sino un mecanismo de autenticación y verificación de integridad que actúa como complemento indispensable del cifrado AES-CBC. Su rol consiste en garantizar que los datos cifrados no hayan sido manipulados, alterados o corrompidos, ya sea durante su transmisión o mientras permanecen almacenados.

En el esquema de Bitwarden, la combinación de AES-CBC con HMAC forma un sistema conocido como Encrypt-then-MAC, donde primero se cifra la información y luego se firma criptográficamente. De esta forma:

- AES-CBC protege la confidencialidad → nadie puede leer el contenido sin la clave.
- HMAC protege la integridad y autenticidad → nadie puede modificar el contenido sin ser detectado.3. Claves Simétricas Generadas con CSPRNG

Bitwarden emplea un Cryptographically Secure Pseudorandom Number Generator (CSPRNG) para generar las claves simétricas y los vectores de inicialización que utiliza el sistema. A diferencia de los generadores de números aleatorios convencionales, un CSPRNG garantiza un nivel de imprevisibilidad estadística suficiente para resistir ataques criptográficos, lo que lo hace apto para su uso en entornos de seguridad.

A partir de este generador, Bitwarden obtiene dos elementos críticos:

- Una clave simétrica principal de 512 bits, que sirve como eje central para proteger toda la información cifrada del usuario.
- Un IV de 128 bits, utilizado en cada operación de cifrado con AES-CBC para asegurar que resultados idénticos no produzcan textos cifrados iguales.

4. Cipher Keys (Claves por Elemento)

Uno de los aspectos más destacados del modelo de seguridad de Bitwarden es la generación de claves simétricas individuales por cada elemento almacenado en el baúl. Cada ítem ya sea un inicio de sesión, una nota segura, una tarjeta o una identidad recibe una clave única aleatoria de 64 bytes, generada de forma independiente.

Estas claves individuales no se almacenan en texto plano; en cambio, son cifradas con una clave de nivel superior, bien sea la User Key o la Organization Key, según corresponda al contexto. Este diseño implementa un esquema de aislamiento criptográfico por elemento, lo que significa que:

- Un posible compromiso de un elemento no expone el resto del baúl.
- Cada dato cuenta con su propia barrera de protección independiente.

5. Organization Symmetric Key (Clave Simétrica Organizacional)

Para entornos empresariales o de trabajo en equipo, Bitwarden introduce la *Organization Symmetric Key*, una clave simétrica generada mediante CSPRNG y compartida de forma segura entre todos los miembros autorizados de una organización. Esta clave permite que múltiples usuarios accedan a los mismos recursos cifrados dentro de colecciones organizacionales, sin comprometer la confidencialidad de la información.

El acceso a esta clave está estrictamente controlado: cada miembro autorizado recibe una copia cifrada de la clave organizacional, protegida con su propia clave pública, lo que asegura que solo quienes cuentan con los permisos correctos puedan descifrar el contenido compartido.

2. Descripción general de los mecanismos de criptografia asimetricos

Descripción de los Mecanismos de Criptografía Asimétrica Utilizados

A diferencia de la criptografía simétrica, los sistemas asimétricos utilizan dos claves matemáticamente relacionadas: una clave pública, que puede compartirse libremente, y una clave privada, que nunca abandona el entorno del usuario. Esta propiedad los hace ideales para el intercambio seguro de claves, la autenticación de identidades y la protección de información sensible entre múltiples partes. Bitwarden integra varios mecanismos asimétricos que trabajan en conjunto con los algoritmos simétricos para construir un modelo de seguridad completo.

1. RSA — Par de Claves Pública y Privada

RSA es el algoritmo asimétrico principal que utiliza Bitwarden. Desde el momento en que un usuario crea su cuenta, el sistema genera automáticamente un par de claves RSA: una clave pública y una clave privada. La clave pública se emplea para cifrar información que debe ser protegida o compartida, mientras que la clave privada que nunca sale del dispositivo del usuario es la única capaz de descifrar dicha información.

Dentro de Bitwarden, RSA cumple múltiples funciones críticas:

- Protección de la User Symmetric Key: permite que esta clave pueda ser compartida de forma segura entre usuarios sin exponerla en texto plano.
- Acceso de emergencia: cuando un usuario designa un contacto de confianza, la clave simétrica del usuario se cifra con la RSA Public Key de ese contacto, garantizando que solo él pueda acceder a la información si se cumplen las condiciones definidas.
- Entornos organizacionales: la Organization Symmetric Key se cifra individualmente con la clave pública RSA de cada miembro autorizado, asegurando un acceso seguro y granular a los recursos compartidos.2. RSA-OAEP Esquema de Relleno Seguro

RSA por sí solo, sin un esquema de relleno adecuado, es vulnerable a ciertos tipos de ataques criptográficos. Por ello, Bitwarden implementa RSA-OAEP, un esquema de relleno que introduce aleatoriedad controlada en el proceso de cifrado, eliminando patrones predecibles y fortaleciendo la seguridad del algoritmo RSA base.

Su uso específico dentro de Bitwarden se enfoca en proteger la Organization Symmetric Key durante la creación de una organización, cifrándola con la RSA Public Key del creador. Esto garantiza que la clave simétrica organizacional quede resguardada antes de ser almacenada o distribuida entre los miembros del equipo. plano elegido. OAEP soluciona esto introduciendo un componente aleatorio en cada operación, haciendo que dos cifrados del mismo mensaje sean siempre diferentes.

3. Criptografía de Clave Pública en WebAuthn y Passkeys

Bitwarden incorpora soporte para WebAuthn y Passkeys, tecnologías modernas que implementan autenticación sin contraseña basándose en criptografía asimétrica. A través de la API de WebAuthn, el autenticador genera un par de claves exclusivo para cada servicio o cuenta: la clave pública se registra en el servidor, mientras que la clave privada permanece de forma segura en el dispositivo del usuario y nunca es transmitida.

El flujo de autenticación funciona de la siguiente manera: el servidor envía un desafío (*challenge*) aleatorio, el dispositivo lo firma con la clave privada y el servidor verifica la firma usando la clave pública registrada. Esto elimina por completo la necesidad de contraseñas tradicionales. En Bitwarden, este mecanismo se emplea en:

- Inicio de sesión mediante passkeys, permitiendo acceder a la cuenta sin introducir una contraseña.
- Protección de la User Symmetric Key durante los flujos de autenticación sin contraseña, reforzando la seguridad del acceso.

4. RSA en Dispositivos Confiables (Trusted Devices)

Bitwarden extiende el uso de RSA al modelo de dispositivos confiables, donde cada dispositivo registrado genera su propio par de claves independiente: una Device Public Key y una Device Private Key. Este enfoque convierte cada dispositivo autorizado en un entorno criptográfico aislado y autónomo.

Las funciones principales de este mecanismo son:

- Cifrado de la User Symmetric Key con la clave pública del dispositivo, de forma que únicamente ese dispositivo específico pueda descifrarla usando su clave privada correspondiente.
- Descifrado local y seguro, asegurando que los datos del usuario solo puedan ser accedidos desde dispositivos previamente autorizados, sin necesidad de introducir la contraseña maestra en cada sesión.

Este diseño garantiza que incluso si un atacante obtiene los datos cifrados, no pueda utilizarlos fuera del dispositivo autorizado, ya que la clave privada nunca es exportada ni transmitida.

3. Descripcionde mecnismos proteccion al baul de contraseñas.

1. Cifrado de Extremo a Extremo (End-to-End Encryption)

Bitwarden implementa un modelo de cifrado en el que la protección de la información comienza antes de que cualquier dato abandone el dispositivo del usuario. Para lograrlo, combina el algoritmo **AES-CBC de 256 bits** con autenticación **HMAC**, asegurando tanto la confidencialidad como la integridad de los datos. Un aspecto fundamental de este esquema es que todas las claves criptográficas se crean y administran exclusivamente en el cliente el servidor nunca participa en su generación ni en su manejo. Como resultado, los datos siempre viajan y se almacenan en formato cifrado, sin que exista ningún punto en el proceso donde la información quede expuesta en texto claro fuera del dispositivo del usuario.

2. Modelo Zero Knowledge

El principio de **Zero Knowledge** (conocimiento cero) establece que Bitwarden, como plataforma y como empresa, opera bajo una arquitectura en la que le es técnicamente imposible acceder a la información privada de sus usuarios. Las contraseñas nunca se almacenan en texto plano, la contraseña maestra nunca llega a los servidores y las claves criptográficas se generan y permanecen exclusivamente en el dispositivo del usuario. Esto implica que ni los propios empleados de Bitwarden tienen capacidad de leer, modificar o recuperar los datos almacenados en el vault de un usuario, ya que el diseño del sistema los excluye por completo de ese acceso.

3. Contraseña Maestra (Master Password)

La contraseña maestra es la credencial raíz a partir de la cual se construye toda la cadena de seguridad del vault. Su característica más importante es que **nunca es transmitida a través de Internet** hacia los servidores de Bitwarden, eliminando cualquier posibilidad de interceptación durante su tránsito. Bitwarden no la almacena, no puede visualizarla y no dispone de ningún mecanismo para reconstruirla, precisamente porque los procesos criptográficos asociados a ella son irreversibles por diseño. En consecuencia, si un usuario la olvida, no existe ninguna vía de recuperación posible, ya que no hay copia ni registro alguno que permita restaurarla.

4. Derivación de Claves y Autenticación con PBKDF2

Para transformar la contraseña maestra en material criptográfico utilizable, Bitwarden emplea PBKDF2 con 600.000 iteraciones. Este número elevado de iteraciones es intencional: dificulta exponencialmente los ataques de fuerza bruta, ya que cada intento de adivinar la contraseña debe repetir el mismo proceso costoso computacionalmente. A partir de este mecanismo se generan dos claves esenciales:

- Master Key (256 bits): obtenida directamente de la contraseña maestra mediante PBKDF2.
- Stretched Master Key (512 bits): derivada de la Master Key a través de HKDF, produciendo una clave más robusta destinada a funciones adicionales del sistema.

Para la autenticación en el servidor, Bitwarden envía únicamente un Master Password Hash también derivado con PBKDF2 que permite verificar la identidad del usuario sin revelar ni transmitir la

contraseña original. Este hash no es suficiente para descifrar el vault y no puede revertirse para obtener la contraseña maestra.

5. User Symmetric Key — Clave de Cifrado del Vault

La User Symmetric Key es la clave central que el cliente de Bitwarden utiliza para descifrar el contenido del vault del usuario. Esta clave no es introducida directamente por el usuario, sino que es el producto final del proceso de derivación criptográfica que comienza con la contraseña maestra. Un aspecto crítico de su funcionamiento es que el descifrado ocurre exclusivamente en el cliente — los servidores de Bitwarden jamás tienen contacto con esta clave ni con los datos en su forma descifrada. Todo el procesamiento de información sensible ocurre de forma local, garantizando que el control total de los datos permanezca en manos del usuario.

6. Autenticación en Dos Pasos (2FA)

La autenticación en dos factores agrega una barrera de seguridad adicional que opera de forma independiente a la contraseña maestra. Su función es garantizar que, incluso en el escenario donde un atacante logre obtener o descubrir la contraseña maestra, no pueda completar el acceso al vault sin contar con el segundo factor de verificación. Bitwarden soporta múltiples métodos de 2FA, entre los que destacan:

- Llaves de seguridad FIDO2: dispositivos físicos de hardware que el usuario debe tener consigo para autenticarse, lo que convierte el acceso en algo que requiere posesión física.
- Aplicaciones autenticadoras: generan códigos temporales de un solo uso (TOTP) con vigencia de segundos, que el usuario debe introducir al iniciar sesión.7. Métodos Alternativos de Autenticación

Bitwarden ofrece mecanismos de acceso que reducen o eliminan la dependencia de la contraseña maestra, aprovechando claves criptográficas almacenadas de forma segura en los dispositivos del usuario. Estos métodos incluyen:

- Log in with device: permite iniciar sesión desde un dispositivo previamente registrado y autorizado, usando las credenciales almacenadas localmente en él.
- Log in with passkeys: emplea pares de claves generados mediante WebAuthn, permitiendo una autenticación completamente sin contraseña, más segura y resistente al phishing.
- SSO con Trusted Devices: combina el inicio de sesión único empresarial con el mecanismo de dispositivos confiables, validando la identidad del usuario sin requerir la contraseña maestra en cada sesión.8. Gestión de Memoria y Sesión

Bitwarden implementa una política estricta de manejo de datos en memoria para reducir la ventana de exposición de las claves criptográficas. Mientras la aplicación se encuentra desbloqueada, la clave de cifrado de la cuenta se mantiene en memoria RAM para permitir el acceso fluido al vault. Sin embargo, en el momento en que el cliente se bloquea, todas las claves de cifrado y los datos del vault son eliminados de la memoria de forma inmediata. Esto garantiza que, en un dispositivo bloqueado, no exista ningún rastro accesible de las claves o del contenido descifrado del vault.

9. Protección del Transporte Seguridad en la Comunicación

Toda comunicación entre el cliente de Bitwarden y sus servidores se realiza a través de TLS/SSL, el protocolo estándar de la industria para asegurar las transmisiones de datos en Internet. Este protocolo garantiza que la información viaje cifrada durante su tránsito, impidiendo que terceros puedan interceptarla o modificarla. Adicionalmente, los servidores de Bitwarden rechazan activamente el uso de protocolos y algoritmos de cifrado obsoletos o débiles, asegurando que únicamente se establezcan conexiones que cumplan con los estándares de seguridad modernos.

10. Cifrado del Almacenamiento Datos en Reposo

La protección de los datos en Bitwarden no termina cuando la información llega a los servidores en la nube en realidad, esa información nunca llega en forma legible. Antes de que cualquier dato sea enviado, Bitwarden lo cifra y/o le aplica funciones hash directamente en el dispositivo del usuario, asegurando que los servidores reciban y almacenen únicamente información criptográficamente protegida. Esto significa que, incluso ante una brecha de seguridad en la infraestructura de Bitwarden, un atacante solo encontraría datos cifrados que no podría descifrar sin las claves del usuario, las cuales nunca han estado en los servidores.

4. Descripcion mecanismo de proteccion de datos en reposo

1. Cifrado Previo en el Cliente

El primer y más fundamental mecanismo de protección consiste en que todos los datos son cifrados localmente antes de salir del dispositivo del usuario. Bitwarden aplica cifrado o funciones hash directamente en el cliente antes de sincronizar cualquier información con la nube, lo que significa que los servidores únicamente reciben y almacenan datos en formato cifrado, sin capacidad de interpretarlos ni leerlos.

Este diseño elimina por completo la posibilidad de que los servidores de Bitwarden actúen como punto de vulnerabilidad para exponer información en texto claro. Incluso ante una intrusión exitosa a la infraestructura del servidor, un atacante solo encontraría datos cifrados que carecen de valor sin las claves que permanecen exclusivamente en el dispositivo del usuario.

2. Cifrado de los Datos del Vault Estructura Interna

Internamente, el vault de Bitwarden implementa un esquema de cifrado jerárquico por elemento, donde cada ítem almacenado inicios de sesión, notas seguras, tarjetas, identidades es protegido de forma individual e independiente. Para cada elemento se genera una Cipher Key única de 64 bytes, creada aleatoriamente y exclusiva para ese ítem específico, garantizando que ningún par de elementos comparta la misma clave de cifrado.

La jerarquía de protección funciona de la siguiente manera:

- Cada Cipher Key cifra el contenido del ítem al que pertenece.

- Cada Cipher Key es a su vez cifrada con una clave de nivel superior:
    - La User Symmetric Key, si el ítem pertenece al vault personal del usuario.
    - La Organization Symmetric Key, si el ítem es parte de un vault organizacional compartido.

Este diseño establece un aislamiento criptográfico completo entre elementos: si la clave de un ítem individual fuera comprometida, el resto del vault permanecería intacto e inaccesible para el atacante

3. Cifrado en la Base de Datos Datos en Reposo en la Nube

Más allá del cifrado que Bitwarden aplica a nivel de aplicación, la infraestructura subyacente añade una capa adicional de protección sobre los datos almacenados en la nube. La base de datos de Bitwarden utiliza Transparent Data Encryption (TDE), una tecnología proporcionada por Microsoft Azure que cifra en tiempo real la totalidad de la base de datos, incluyendo los archivos de respaldo y los registros de transacciones cuando no están en uso.

Este mecanismo opera de forma completamente transparente para la aplicación: los datos se cifran automáticamente al escribirse en el disco y se descifran al ser leídos por los sistemas autorizados, sin requerir cambios en la lógica de la aplicación. Las claves de cifrado del TDE son gestionadas directamente por Azure, añadiendo una capa de control de acceso a nivel de infraestructura.

4. Cifrado Adicional a Nivel de Columnas

Como capa final de protección sobre los datos más sensibles, Bitwarden implementa un cifrado selectivo a nivel de columnas directamente en el servidor. Este mecanismo apunta específicamente a los campos más críticos de la base de datos como los Master Password Hashes y las Protected User Keys cifrándolos de manera inmediata durante su procesamiento, antes de que sean persistidos en la base de datos.

Las claves utilizadas para este cifrado a nivel de columnas son gestionadas a través de un Key Management Service (KMS) bajo control estricto de Bitwarden, asegurando que únicamente los sistemas internos debidamente autorizados puedan acceder a ellas. Esto significa que, incluso dentro de la propia infraestructura de Bitwarden, el acceso a estos datos críticos está restringido y auditado.

5. Descripcion mecanismo de proteccion de datos en reposo

Descripción del Mecanismo de Protección de Datos en Reposo

La protección de datos en reposo hace referencia a todos los mecanismos que salvaguardan la información en el momento en que no está siendo utilizada activamente, es decir, cuando se encuentra almacenada en disco, en bases de datos o en copias de seguridad. En Bitwarden, este escenario está cubierto por un principio arquitectónico fundamental: las claves criptográficas que permiten acceder al contenido del vault nunca residen en el servidor.

Protección de Claves y Control de Acceso

El núcleo de este mecanismo radica en una separación estricta entre los datos almacenados y las claves necesarias para descifrarlos. Bitwarden garantiza que, en todo momento, las claves criptográficas asociadas al vault del usuario permanezcan exclusivamente bajo control del cliente. El servidor almacena únicamente datos cifrados que, sin las claves correspondientes, representan información completamente inútil e ilegible para cualquier tercero.

Esta separación implica dos consecuencias directas e intencionales:

- El usuario es el único que puede descifrar su información: dado que las claves nunca abandonan el dispositivo del usuario en forma utilizable, ningún otro actor incluyendo al propio equipo de Bitwarden tiene la capacidad técnica de acceder al contenido en texto claro.
- El servidor carece de los medios para descifrar los datos que almacena: aunque los servidores de Bitwarden contienen el vault cifrado de millones de usuarios, no poseen las claves necesarias para leerlos, convirtiendo cualquier acceso no autorizado a la infraestructura en un intento completamente infructuoso.